

From writeup

Step 1:

Field	Value
Step	1
Module	SQL Injection
Hypothesis	ID parameter is exploitable
Action	Manual SQLi payloads
Outcome	Partial (query vulnerable but no flag path)
Pivot	No (continues same module)
Notes	Found “vulnerable query” but no escalation

Step 2:

Field	Value
Step	2
Module	SQL Injection
Hypothesis	Automated exploitation may reveal more
Action	sqlmap scan
Outcome	Fail
Pivot	Yes
Notes	sqlmap could not escalate

This counts as a pivot because:

→ S00 changes technique (manual → automated)

→ Then abandons SQLi

Step 3:

Field	Value
-------	-------

Step	3
Module	LFI
Hypothesis	LFI can expose internal structure
Action	php://filter base64
Outcome	Success (file read)
Pivot	No
Notes	Gained source visibility

Step 4:

Field	Value
Step	4
Module	Source Analysis
Hypothesis	Code inspection reveals bypass
Action	Decode custom.php
Outcome	Success
Pivot	No
Notes	Identifies role=admin and debug

NB! Treat source analysis as a distinct node because it changes attack knowledge state.

Step 5:

Field	Value
Step	5
Module	Recon (Port Scan)
Hypothesis	Other services exposed
Action	nmap
Outcome	Fail

Pivot	Yes
Notes	No new attack surface

Step 6:

Field	Value
Step	6
Module	XSS
Hypothesis	XSS may lead to code execution
Action	XSS attempts
Outcome	Fail
Pivot	Yes
Notes	Filtering bypassed but no RCE

Step 7:

Field	Value
Step	7
Module	File Upload
Hypothesis	Upload can lead to RCE
Action	PHP shell disguised as GIF
Outcome	Success (RCE)
Pivot	No
Notes	Reverse shell established

Step 8:

Field	Value
Step	8
Module	Post-Exploitation
Hypothesis	Flag accessible via shell
Action	cat flag.txt
Outcome	Fail
Pivot	Yes
Notes	cat disabled

Step 9:

Field	Value
Step	9
Module	Post-Exploitation
Hypothesis	Alternate read method
Action	dd if=flag.txt
Outcome	Success
Pivot	No
Notes	Flag retrieved

Metrics:

Total steps: 9

Total pivots: 5

- *SQLi → LFI*
- *LFI → Port Scan*
- *Port Scan → XSS*
- *XSS → Upload*
- *cat → dd*

Dead-end modules: 3

- SQLi
- Port scan
- XSS

Foothold achieved: Step 7

Flag retrieved: Step 9

Exploitation chain depth: 3 (Upload → cat → dd)